מבחן - פיתוח DevOps

כללי:

להלן מבחן לתפקיד פיתוח DevOps ביחידת טכנולוגיות וסייבר, במסגרת פרויקט "נימבוס", הוחלט על הקמת סביבת ענן משרדית באזור הנחיתה המרכזי עבור מערך הדיגיטל הלאומי, אשר מטרתו לשמש תשתית לכלל המוצרים של המערך בענן ציבורי.
סביבת הענן המשרדית תאפשר ניהול מרכזי של כלל מוצרי הדיגיטל ורכיבי הענן, תוך שמירה על מדיניות של אבטחת מידע.

הנחיות לנבחן:

1. אנו מתחייבים שלא יעשה שימוש מקצועי (ציבורי או פרטי) בחומר שנכתב על ידי המועמדים.
2. המשרה מיועדת ל-2 המינים.
3. זהו מבחן אותו אתם מתבקשים לבצע בכוחות עצמכם וללא סיוע של אנשים אחרים.

בהצלחה!

שאלה 1:

הקטע הבא הוא קוד Terraform שמנסה ליצור Auto Scaling Group עם ALB, אך יש בו מספר בעיות.
עליך לזהות את הבעיות ולהסביר ביצד ניתן לתקן אותן.

```
provider "aws" {
  region = "il-central-1"
}

resource "aws_launch_configuration" "this" {
  name          = "example-lc"
  image_id      = "ami-0c55b159cbfafe1f0"
  instance_type = "t2.micro"
  security_groups = [aws_security_group.example.id]
}

resource "aws_autoscaling_group" "example" {
  launch_configuration = aws_launch_configuration.example.id
  min_size             = 2
  max_size             = 5
  desired_capacity     = 3
  vpc_zone_identifier  = ["subnet-12345678", "subnet-87654321"]

  target_group_arns = [aws_lb_target_group.example.arn]
}

resource "aws_lb" "lb" {
  name               = "example-lb"
  internal           = false
  load_balancer_type = "application"
  security_groups    = [aws_security_group.sec.id]
  subnets            = ["subnet-12345678", "subnet-87654321"]
}

resource "aws_lb_target_group" "tg" {
  name     = "example-tg"
  port     = 80
  protocol = "HTTP"
  vpc_id   = "vpc-12345678"
}

resource "aws_security_group" "sec" {
  name_prefix = "example-sg"
  vpc_id      = "vpc-12345678"
}
```

1. מהם הבעיות בקוד?
2. ביצד היית מתקן אותן?

שאלה 2:

להלן קטע קוד:

```python
import boto3
import json

s3 = boto3.client("s3")
bucket_name = "exam-aws-devops-bucket"

s3.create_bucket(
    Bucket=bucket_name,
    CreateBucketConfiguration={"LocationConstraint": "il-central-1"},
)

policy = {
    "Version": "2012-10-17",
    "Statement": [
        {
            "Sid": "PublicReadGetObject",
            "Effect": "Allow",
            "Principal": "*",
            "Action": "s3:GetObject",
            "Resource": f"arn:aws:s3:::{bucket_name}/*"
        }
    ]
}

s3.put_bucket_policy(Bucket=bucket_name, Policy=json.dumps(policy))
```

1. מה הקוד הזה עושה?
2. אילו בעיות אבטחה יש כאן, וביצד היית מונע אותן?
3. מה יקרה אם נריץ את הקוד הזה בחשבון שבו ברירת המחדל היא חסימה גישה ציבורית לS3?
4. ביצד היית מתקן את הקוד כך שיאפשר רק למשתמשים מורשים לגשת ל-S3?

שאלה 3:

להלן IAM Policy

```
1  {
2      "Version": "2012-10-17",
3      "Statement": [
4          {
5              "Effect": "Allow",
6              "Action": [
7                  "s3:ListBucket",
8                  "s3:GetObject",
9                  "s3:PutObject"
10             ],
11             "Resource": "*"
12         }
13     ]
14 }
```

1. למי ה-Policy מאפשר גישה, ואילו פעולות מותרות?
2. האם יש כאן סיכון אבטחה? אם כן, מהו?
3. כיצד היית מגביל את הPolicy כך שיהיה בטוח יותר?

שאלה 4:

יש לך VPC עם שני Security Groups (SG):

1. SG לשרתים אפליקטיביים שמאפשר חיבורי HTTPS מהאינטרנט.
2. SG לבסיס נתונים RDS שמאפשר חיבורי mysql.

להלן מספר שאלות:

1. איך תוודא שבסיס הנתונים מוגן מפני גישה חיצונית?
2. האם עדיף להשתמש ב-NACLs במקום SG? הסבר את תשובתך.
3. איך היית מאפשר גישה מאובטחת ל-RDS למפתחים לצורכי דיבוג?

שאלה 5:

יש לך אפליקציה שמקבלת קבצים מלקוחות אל S3 Bucket ולאחר מכן Lambda מעבדת אותם ושומרת תוצאה ל-DynamoDB.

1. תאר ארכיטקטורה מלאה לזרימה הזו, כולל: איך הקבצים מגיעים ל-S3, איך Lambda מופעלת, ואיך היא ניגשת לדינמוDB.
2. כתוב (ברמת high-level) איזה IAM Role צריך לפונקציית ה-Lambda, ואילו הרשאות מינימליות תיתן לה.
3. איך תדאג שה-Lambda לא תיכשל כשיש הרבה קבצים במקביל?

שאלה 6:

בארגון שלנו מופעל AWS CloudTrail שכותב לוגים לחשבון מרכזי, ואתה רוצה לזהות בזמן אמת אירועי אבטחה חשודים, למשל:

- יצירה או מחיקה של Access Key למשתמש IAM.
- שינוי ב-Security Group שמפתח פורטים החוצה לאינטרנט.

1. תאר ארכיטקטורה שמאפשרת לזהות את האירועים האלה בזמן אמת ולהפעיל פעולה אוטומטית (למשל שליחת הודעה ל-Slack או הרצת Lambda שמבטלת את השינוי). התייחס ל- CloudTrail, EventBridge (CloudWatch Events), CloudWatch Logs, וליעד כמו Lambda או SNS.
2. כיצד תגדיר Event Pattern ב-EventBridge כך שיקלוט רק אירועים רלוונטיים? תן דוגמה עקרונית לשדות מרכזיים ב-JSON של האירוע שבהם תשתמש לסינון.
3. איך תוודא שהלוגים והאירועים עצמם מוגנים ושלא ניתן למחוק או לשנות אותם בקלות?
4. מה ההבדל בין שימוש ב-CloudWatch Logs Metric Filter + Alarm לבין EventBridge Rule ישירות על אירועי CloudTrail, ומתי תעדיף כל אחת מהגישות?

בהצלחה 😊